

| RISK MATRIX |               |                                          | LIKELIHOOD                                |                         |                        |                   |                        |
|-------------|---------------|------------------------------------------|-------------------------------------------|-------------------------|------------------------|-------------------|------------------------|
|             |               |                                          | Rare                                      | Unlikely                | Possible               | Likely            | Almost Certain         |
|             |               |                                          | (description)<br>Highly unlikely to occur | Unexpected but possible | May occur at some time | Expected to occur | Highly likely to occur |
| CONSEQUENCE | Severe        | Significant damage threatening company   | HIGH                                      | VERY HIGH               | VERY HIGH              | EXTREME           | EXTREME                |
|             | Major         | Critical operational or financial impact | HIGH                                      | HIGH                    | VERY HIGH              | VERY HIGH         | EXTREME                |
|             | Moderate      | Noticable but manageable impact          | LOW                                       | MEDIUM                  | MEDIUM                 | HIGH              | VERY HIGH              |
|             | Minor         | Minimal impact or disruption             | VERY LOW                                  | LOW                     | MEDIUM                 | MEDIUM            | HIGH                   |
|             | Insignificant | Minimal or negligible impact             | VERY LOW                                  | VERY LOW                | LOW                    | MEDIUM            | MEDIUM                 |

| Context - Asset(s) that we are trying to protect                                                                                                                                                         |  |  |  |  |  |  |  |  |  |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|--|--|--|--|--|--|--|--|
| Assets that need to be protected are:<br>- Sensitive and confidential internal information<br>- Personal customer data<br>- Financial records and related data<br>- Physical infrastructure and hardware |  |  |  |  |  |  |  |  |  |

| Risk |                           |                                                                                                                                                                                                                                       |                                                                                             |                                                                                                   | Inherent Risk Rating |             |            | Current Risk Rating                                                                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |            |             |            | Target Risk Rating                                                                                                                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |            |             |            |
|------|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|----------------------|-------------|------------|--------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|-------------|------------|--------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|-------------|------------|
| ID   | Title                     | Description                                                                                                                                                                                                                           | Sources or Causes of Risk                                                                   | Consequences of Risk                                                                              | Likelihood           | Consequence | Risk Level | Existing control measures                                                                        | Effectiveness of existing control measures                                                                                                                                                                                                                                                                                                                                                                                                                                | Likelihood | Consequence | Risk Level | Additional control measures                                                                                                                | Effectiveness of additional control measures                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          | Likelihood | Consequence | Risk Level |
| R01  | Natural Disaster          | Natural events (such as earthquakes or floods) that cause damage to a company's physical assets, endanger employees, and disrupt operations.                                                                                          | - Natural phenomena                                                                         | - Infrastructure damage<br>- Financial loss<br>- Potential loss of life                           | Rare                 | Severe      | HIGH       | - Disaster Recovery Plan<br>- Training and emergency drills<br>- Building reinforcement measures | <b>Disaster recovery plan (Excellent Control)</b> - Provides structured procedures to restore critical systems and resume operations after a natural disaster.<br><br><b>Training and drills (Good control)</b> - Ensures employees understand evacuation and response procedures, reducing the impact during an event.<br><br><b>Building reinforcement measures (Excellent control)</b> - Strengthens physical structures to minimize damage and improve safety.        | Rare       | Moderate    | LOW        | <b>Accept</b><br>- Regular testing and maintenance                                                                                         | <b>Regular testing and maintenance (Good Control)</b> - Ensures that the disaster recovery processes, training, and building protections remain effective and up to date.                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | Rare       | Moderate    | LOW        |
| R02  | Regulatory Non-Compliance | Failure to meet cybersecurity standards or regulatory requirements, leaving the company exposed to vulnerabilities and potential penalties.                                                                                           | - Inadequate security measures<br>- Insufficient auditing<br>- Gaps in compliance processes | - Fines<br>- Reputational damage<br>- Legal liabilities<br>- Operational disruption               | Possible             | Major       | VERY HIGH  | - Compliance audit<br>- Risk assessment<br>- Incident response plan                              | <b>Compliance audit (Excellent Control)</b> - Regular audits verifies company's compliance and regulatory requirements, reducing the likelihood of compliance gaps.<br><br><b>Risk assessments (Good Control)</b> - Identifies vulnerabilities/weaknesses and strengthens security posture, reducing compliance related risks.<br><br><b>Incident Response Plan (Good Control)</b> - Ensures structured response procedures are in place to handle incidents effectively. | Possible   | Major       | VERY HIGH  | <b>Treat</b><br>- Continuous monitoring<br>- Data classification                                                                           | <b>Continuous monitoring (Good Control)</b> - Ensures compliance audit, risk assessment, and incident plan are effective and up-to-date.<br><br><b>Data classification (Good Control)</b> - Supports regulatory requirements by ensuring sensitive information is labelled, handled, and protected appropriately                                                                                                                                                                                                                                                                                                                                      | Unlikely   | Major       | HIGH       |
| R03  | Social Engineering        | A manipulation tactic from attackers that deceives the individual to take unsafe actions, including to compromise security or reveal sensitive information. These attacks exploits human error and the lack of awareness.             | - External attacker<br>- Lack of employee awareness                                         | - Compromised systems<br>- Data loss<br>- Reputational damage                                     | Possible             | Moderate    | MEDIUM     | - Security awareness training<br>- Incident response plan                                        | <b>Security Awareness Training (Good Control)</b> - Regular awareness training helps employees follow security best practices and how to identify suspicious activities.<br><br><b>Incident Response Plan (Excellent Control)</b> - Provides clear procedures for responding to security incidents caused by social engineering attacks.                                                                                                                                  | Possible   | Moderate    | MEDIUM     | <b>Treat</b><br>- Role based access control<br>- Email filtering<br>- Anti-virus software<br>- Phishing simulations                        | <b>Role based access control (Excellent Control)</b> - Restricts access to only what employees require for their responsibilities, reducing potential impact.<br><br><b>Email filtering (Good Control)</b> - Identifies malicious/suspicious emails, reducing likelihood of successful phishing attempts.<br><br><b>Anti-virus software (Excellent Control)</b> - Detects and removes malicious software associated with social engineering attacks.<br><br><b>Phishing simulations (Good Control)</b> - Reinforces awareness training by providing realistic testing of employee behaviour, reducing the likelihood of successful phishing attempts. | Unlikely   | Moderate    | MEDIUM     |
| R04  | Cyber Attacks             | Hackers attempt to gain unauthorized access to a company's systems to steal data, disrupt business, manipulate information, or demand ransom. Attackers can be from organized crime groups, nation-states, or are individual hackers. | - External attacker<br>- Inadequate security measures                                       | - Financial loss<br>- Reputational damage<br>- Data loss/manipulation<br>- Operational disruption | Likely               | Major       | VERY HIGH  | - Intrusion Detection System<br>- Regular patches<br>- Firewall<br>- Data encryption             | <b>Intrusion Detection System (Excellent Control)</b> - Properly configured and monitor networks to detect suspicious activity.<br><br><b>Firewalls (Good Control)</b> - Monitors and filters network traffic with predefined rules to reduce exposure.<br><br><b>Data encryption (Good Control)</b> - Protects sensitive data, reducing impact if accessed.<br><br><b>Regular patches (Good Control)</b> - Reduces vulnerabilities and minimizes attack surface.         | Possible   | Major       | VERY HIGH  | <b>Treat</b><br>- Multi-Factor Authentication<br>- Network segmentation<br>- Trend analysis<br>- Penetration Testing                       | <b>Multi-factor authentication (Good Control)</b> - Adds a second layer of authentication, reducing likelihood of unauthorized access.<br><br><b>Network segmentation (Excellent Control)</b> - Limits spread and impact of attacks by isolating systems into subnets.<br><br><b>Trend analysis (Moderate Control)</b> Analyzes attack patterns to anticipate and prevent future threats.<br><br><b>Penetration Testing (Good Control)</b> - Simulates attacks to identify and fix vulnerabilities, reducing the likelihood.                                                                                                                          | Possible   | Moderate    | MEDIUM     |
| R05  | Tailgating                | An unauthorized person follows an authorized person into a restricted area, bypassing physical security controls.                                                                                                                     | - External attacker                                                                         | - Unauthorized access<br>- Physical damage<br>- Theft                                             | Possible             | Moderate    | MEDIUM     | - Security awareness training                                                                    | <b>Security Awareness Training (Good Control)</b> - Regular training educates employees about physical security risks and security best practices.                                                                                                                                                                                                                                                                                                                        | Possible   | Moderate    | MEDIUM     | <b>Treat</b><br>- Physical barriers (such as turnstiles)<br>- Role based access control                                                    | <b>Physical barriers (Excellent Control)</b> - Prevents unauthorized entry, reducing likelihood.<br><br><b>Role based access control (Good Control)</b> - Ensures employees only have access to areas necessary for their responsibilities, limiting potential impact                                                                                                                                                                                                                                                                                                                                                                                 | Rare       | Moderate    | LOW        |
| R06  | Employee Negligence       | Employees fail to follow security protocols accidentally or carelessly, resulting in risk for the company assets.                                                                                                                     | - Lack of employee awareness<br>- Insufficient training<br>- Careless behaviour             | - Operational disruption<br>- Reputational damage<br>- Financial loss<br>- Data loss/manipulation | Possible             | Moderate    | MEDIUM     | - Security awareness training                                                                    | <b>Security Awareness Training - (Good Control)</b> - Regular training educates employees on security best practices, reducing likelihood of negligent actions.                                                                                                                                                                                                                                                                                                           | Possible   | Moderate    | MEDIUM     | <b>Treat</b><br>- Role based access control<br>- Network segmentation<br>- Multi-Factor Authentication<br>- Strong password policies       | <b>Role based access control (Excellent Control)</b> - Ensures employees only have access to areas necessary for their responsibilities, limiting potential impact.<br><br><b>Network segmentation (Excellent Control)</b> - Limits potential impact if employees make mistakes.<br><br><b>Multi-factor authentication (Good Control)</b> - Adds a second layer of authentication, reducing likelihood of unauthorized access from negligent password policies.<br><br><b>Strong password policies (Good Control)</b> - Enforces secure passwords, reducing likelihood of account compromise.                                                         | Unlikely   | Moderate    | MEDIUM     |
| R##  | NA                        | NA                                                                                                                                                                                                                                    | NA                                                                                          | NA                                                                                                |                      |             |            | NA                                                                                               | <b>Excellent / Good / Moderate / Weak</b><br>student to pick effectiveness and provide a description of existing control measures                                                                                                                                                                                                                                                                                                                                         |            |             |            | <b>Accept / Treat / Avoid / Transfer</b><br>student to pick mitigating action and provide a description of any additional control measures | <b>Excellent / Good / Moderate / Weak</b><br>student to pick effectiveness and provide a description of any additional control measures                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |            |             |            |